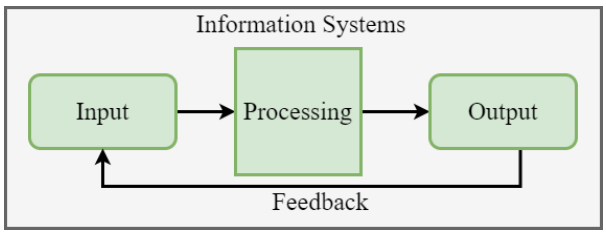
Information systems are combinations of hardware, software, and telecommunications networks that people build and use to collect, create, and distribute useful data, typically in organizational settings.

Some companies like eBay, Amazon, Alibaba, and Google are built completely on using information systems and technology to work.

The Components of Information Systems:-

The components that allow an information system to function effectively and efficiently are known as its operating elements. They are as follows:

- **Hardware:** A system's physical components, such as computer equipment, peripheral devices, and other supporting equipment.
- **Software:** A set of instructions that instructs the hardware on what to do. System software (such as the operating system) and application software are both included.
- **Data:** Information that the system stores and processes. It can include both structured (like a database) and unstructured data (such as a text document).
- **Procedures:** The steps and processes that are followed to complete specific tasks such as data entry, information processing, and report generation.
- **People:** Those who use the system as well as those who support and maintain it.
- **Network:** The communication channels that connect the various system components and allow them to work together.
- **Policies and security measures:** The guidelines and measures that ensure the system's information's confidentiality, integrity, and availability.



Types of Information Systems

1. Operations Support Systems or Transaction Processing System

It handles day-to-day transactions, such as order processing and payroll. For frontline staff, this system provides information necessary to handle an organization’s daily operations, such as inventory reports and customer service records.

2. Management Information Systems

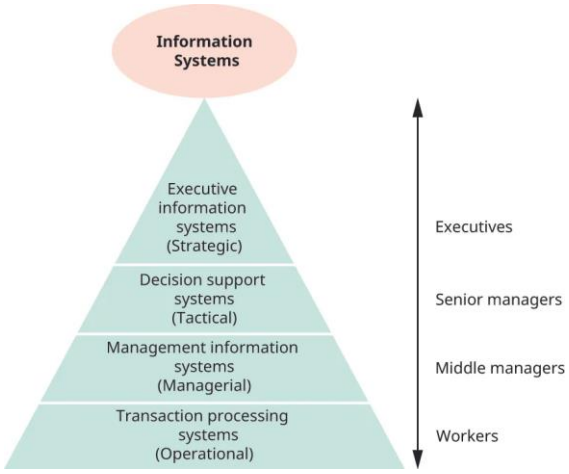
These systems integrate hardware and software to help an organization's main functions. They collect data from different systems. The data is then analysed to help managers make decisions for the business.

3. Decision Support Systems

A decision support system (DSS) assists in decision-making by providing interactive tools and access to data analysis. Typically, senior managers use a DSS to obtain tactical information that helps them make routine, short-term decisions about an organization's operations. This helps ensure that organizations stay on track to achieve long-term goals and objectives.

4. Executive Information Systems

These are management support systems specifically for senior executives. Executive information systems help top managers make high-level decisions for the entire organization.



Systems Development Life Cycle

The Systems Development Life Cycle (SDLC) was first developed in the 1960s to manage the large software projects associated with corporate systems running on mainframes. This approach to software development is very structured and risk averse, designed to manage large projects that include multiple programmers and systems that have a large impact on the organization. It requires a clear, upfront understanding of what the software is supposed to do and is not amenable to design changes. This approach is roughly similar to an assembly line process, where it is clear to all stakeholders what the end product should do and that major changes are difficult and costly to implement.

Various definitions of the SDLC methodology exist, but most contain the following phases.

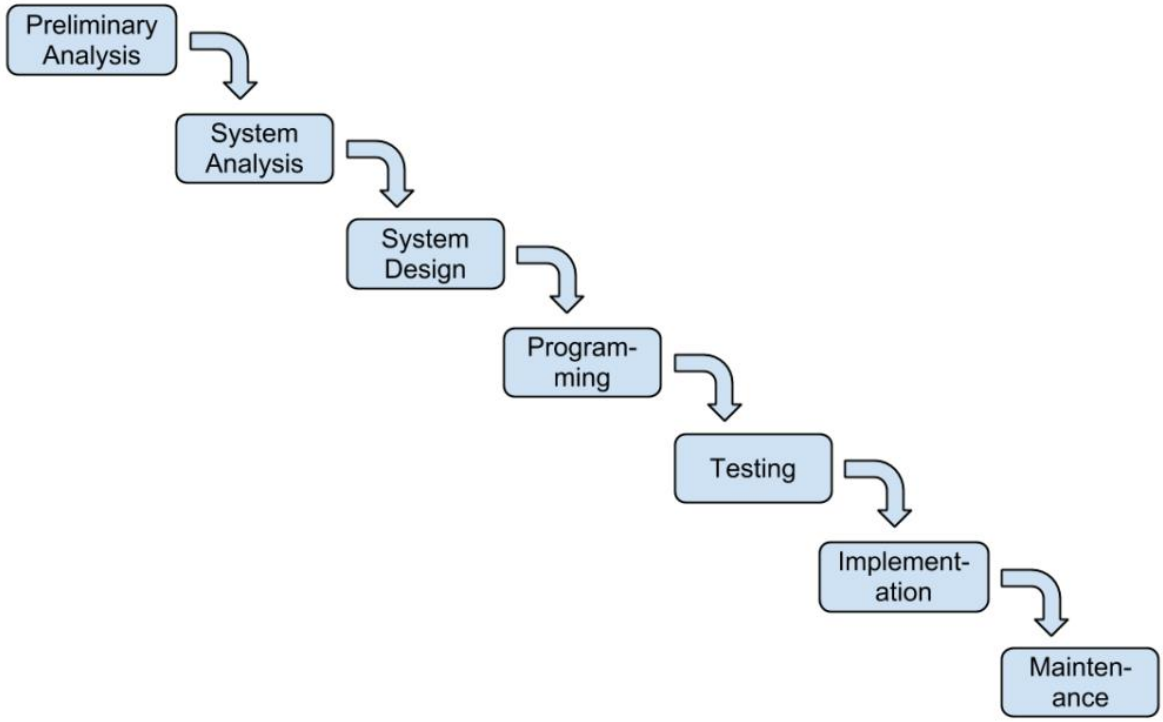
1. ***Preliminary Analysis.***

    - Analyzing potential application areas.

- Identifying the economics of information gathering.
- Performing preliminary cost benefit studies.
- Determining the complexity of data and processes.
- Setting up priorities among application.

2. ***System Analysis***. In this phase one or more system analysts work with different stakeholder groups to determine the specific requirements for the new system. No programming is done in this step. Instead, procedures are documented, key players/users are interviewed, and data requirements are developed in order to get an overall impression of exactly what the system is supposed to do. The result of this phase is a system requirements document and may be done by someone with a title of Systems Analyst.
3. ***System Design***. In this phase, a designer takes the system requirements document created in the previous phase and develops the specific technical details required for the system. It is in this phase that the business requirements are translated into **specific technical requirements**. The design for the user interface, database, data inputs and outputs, and reporting are developed here. The result of this phase is a system design document. This document will have everything a programmer needs to actually create the system and may be done by someone with a title of Systems Analyst, Developer, or Systems Architect, based on the scale of the project.
4. *Programming.* The code finally gets written in the programming phase. Using the system design document as a guide, programmers develop the software. The result of this phase is an initial working program that meets the requirements specified in the system analysis phase and the design developed in the system design phase. These tasks are done by persons with titles such as Developer, Software Engineer, Programmer, or Coder.
5. *Testing.* In the testing phase the software program developed in the programming phase is put through a series of structured tests. The first is a unit test, which evaluates individual parts of the code for errors or bugs. This is followed by a system test in which the different components of the system are tested to ensure that they work together properly. Finally, the user acceptance test allows those that will be using the software to test the system to ensure that it meets their standards. **Any bugs, errors, or problems** found during testing are resolved and then the software is tested again. These tasks are done by persons with titles such as Tester, Testing Analyst, or Quality Assurance.
6. *Implementation.* Once the new system is developed and tested, it has to be implemented in the organization. This phase includes training the users, providing documentation, and data conversion from the previous system to the new system. Implementation can take many forms, depending on the type of system, the number and type of users, and how urgent it is that the system become operational. These different forms of implementation are covered later in the chapter.
7. *Maintenance.* This final phase takes place once the implementation phase is complete. In the maintenance phase the system has a structured support process in

place. Reported bugs are fixed and requests for new features are evaluated and implemented. Also, system updates and backups of the software are made for each new version of the program. Since maintenance is normally an Operating Expense (OPEX) while much of development is a Capital Expense (CAPEX), funds normally come out of different budgets or cost centers.



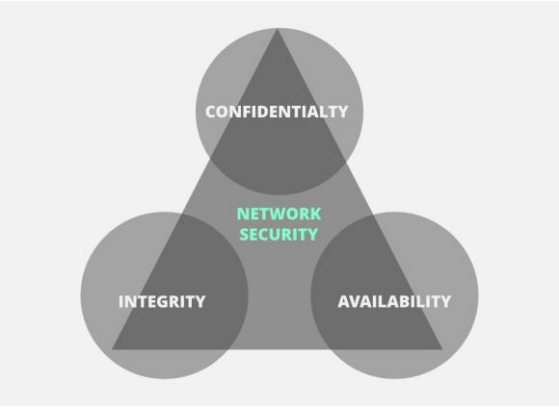
The SDLC method

The SDLC methodology is sometimes referred to as the waterfall methodology to represent how each step is a separate part of the process. Only when one step is completed can another step begin. After each step an organization must decide when to move to the next step. This methodology has been criticized for being quite rigid, allowing movement in only one direction, namely, forward in the cycle. For example, changes to the requirements are not allowed once the process has begun. No software is available until after the programming phase.

Again, SDLC was developed for large, structured projects. Projects using SDLC can sometimes take months or years to complete. Because of its inflexibility and the availability of new programming techniques and tools, many other software development methodologies have been developed. Many of these retain some of the underlying concepts of SDLC, but are not as rigid.

Introduction to Information Security and CIA triad

Information Security:- Information security is the practice of protecting systems, networks, and data from digital attacks by ensuring their Confidentiality, Integrity, and Availability (the CIA Triad).



Confidentiality

- **What it is**:

  Ensuring that information is kept private and is only accessible to authorized users.

- **How to achieve it**:

  Using encryption, implementing strict access controls, and employing authentication methods like multi-factor authentication.

- **Example**:
  A bank customer using a debit card and PIN to access their account ensures confidentiality by restricting access to their financial information to only themselves.

Integrity

- **What it is**:

  The assurance that information is accurate, consistent, and trustworthy, and has not been altered or tampered without authorization.

- **How to achieve it**:

  Employing techniques like hashing to verify data integrity, using digital signatures to confirm data hasn't been changed, and maintaining proper version control.

- **Example**:
  A bank's system ensures data integrity by diligently preserving all transfer and withdrawal records in the customer's account, guaranteeing their accuracy.

Availability

- **What it is**:

  Making sure that systems, networks, and information are accessible and usable by authorized individuals whenever they are needed.

- **How to achieve it**:

  Implementing reliable backups, setting up redundant systems (like failover plans), performing regular hardware and software maintenance, and building resilient infrastructure.

- **Example**:
  An ATM's continuous operation and public accessibility represent availability, ensuring customers can access their bank balance at any time.

The need for Information security:
Information security is important to keep private and important data safe from people who shouldn't be able to see, use, share, damage, change, or delete it. These are some of the most important reasons why it's important to keep information safe:

- **Protecting Confidential Information:** Personal data, bank records, trade secrets, and intellectual property are all examples of confidential information that needs to be kept safe so it doesn't get into the wrong hands. People can steal your name, commit fraud, or do other bad things with this kind of information because it is valuable.
- **Complying with Regulations:** A lot of fields, like healthcare, finance, and government, have to follow strict rules and laws that tell them how to keep private info safe. If these rules aren't followed, the group could face legal and financial consequences as well as damage to its reputation.
- **Maintaining Business Continuity:** Information security helps make sure that important business processes can keep going even if there is a disaster, like a cyberattack or a natural disaster. If a company doesn't have the right security measures in place, its data and systems could be hacked, which would cause a lot of downtime and lost money.
- **Protecting Customer Trust:** Customers expect businesses to keep their info safe. Customers may not trust a business after a breach or data leak, which can cost them money and hurt their image.
- **Preventing Cyber-attacks**: Cyberattacks like viruses, malware, phishing, and ransomware are getting smarter and more common. Information security helps stop these threats before they happen and lessens their effects when they do.
- **Protecting Employee Information:** Companies must also keep information about their employees safe, like personal information, health records, and salary records. Cybercriminals often go after this kind of information, and if they get it, they can use it to steal your name or your money.

Threats to Information Security:

1. Types of Cyber Attacks: Cyber-attacks are a major threat to information security and can take many forms, including:

- **Malware:** Malicious software designed to damage or disrupt computer systems. This includes viruses, worms, and Trojans.
- **Brute Force attack:** A brute force attack is a hacking method that uses trial and error to crack passwords, login credentials, and encryption keys.
- **Phishing:** Fraudulent emails or websites designed to trick users into disclosing sensitive information such as passwords or credit card numbers.
- **Eavesdropping:** An eavesdropping attack occurs when a hacker intercepts, deletes, or modifies data that is transmitted between two devices. Eavesdropping, also known as sniffing or snooping, relies on unsecured network communications to access data in transit between devices.

- **Man-in-the-Middle:** A man-in-the-middle (MitM) attack is a form of cyberattack in which criminals exploiting weak web-based protocols insert themselves between entities in a communication channel to steal data.
- **Denial of Service (DoS) attacks:** Attacks that aim to make a system or network unavailable to its intended users by overwhelming it with traffic.
- **Ransomware:** Malware that encrypts files on a computer system and demands a ransom payment in exchange for the decryption key.
- **Social engineering:** The use of psychological manipulation to trick individuals into disclosing sensitive information or performing actions that compromise security.

2. Risks posed by Cyber Attacks: Cyber-attacks pose a significant risk to organizations and individuals. Some of the risks posed by these attacks include:

- **Data Loss:** Cyber-attacks can result in the theft or destruction of sensitive information, leading to data loss.
- **Reputation Damage:** Cyber-attacks can damage an organization's reputation and credibility, which can be difficult and expensive to repair.

Information Assurance and Security Risk Analysis:

What is Information Assurance (IA)?

- IA is a comprehensive approach to managing information risks, encompassing physical, technical, and administrative measures to protect information and information systems.
- It focuses on maintaining the availability, integrity, authenticity, confidentiality, and non-repudiation of information.
- IA is often considered a superset of information security, providing a broader set of guarantees for information and systems.

What is Security Risk Analysis?

- Security risk analysis is the process of identifying, analyzing, and prioritizing potential threats and vulnerabilities to an organization's data and systems.
- It involves:
  - **Identifying Assets:** Recognizing critical data and IT systems that need protection.
  - **Identifying Vulnerabilities:** Pinpointing weaknesses in systems and practices that could be exploited.
  - **Identifying Threats:** Recognizing potential sources of harm, such as cyber-attacks or human error.
  - **Determining Impact:** Assessing the potential consequences (financial, operational, reputational) if a risk materializes.
  - **Determining Likelihood:** Estimating the probability of a specific threat occurring.
  - **Identifying Existing Controls:** Listing the measures already in place to reduce risks.

How IA and Risk Analysis Work Together

- IA uses risk analysis to inform security policies, technical controls (like firewalls and encryption), and other security measures.

- By **understanding the nature and likelihood of risks**, organizations can strategically allocate resources to the most critical areas, ensuring the security of their most valuable information assets.
- **Periodic risk assessments** are crucial for continually improving an organization's security posture and adapting to new threats.

- **Cyber Security:**
  Cyber Security refers to the **practice of protecting systems, networks, and data** from digital attacks, unauthorized access, damage, or theft.